חלק ב׳

דו״ח חקירה מקצועי להסלמה ל-Tier 2

מלאו את השדות הבאים כפי שהייתם מגישים אותם בפועל לצוות Tier 2 / IR. ניתן להדפיס / לייצא בסיום.

EXECUTIVE SUMMARY — תקציר מנהלים

בשעה 8:12 בבוקר, בעקבות הורדה של קובץ חשוד ממייל פישינג על תחנה של עובד, נגנב בין היתר אישורים של המשתמש admin-dana, בעזרת המשתמש הזה התוקף יכל לקרוא את כל המידע של המסמכים הפיננסיים בשרת המרכזי של הדומיין. לאחר מכן ידוע שהתוקף הבריח מידע בגודל של לפחות 1.4 GB לתשתית הענן שלו כארבע וחצי שעות מאוחר יותר. האירוע בחומרת critical ודורש טיפול בהקדם.

SCOPE — היקף האירוע והישויות המעורבות

תחנות: WKS-YCOHEN (10.10.2.45) - patient zero
משתמשים: MERIDIAN\admin_dana, y.cohen
אישורים גנובים: MERIDIAN\admin_dana
מערכות נגועות: FS01/Finance - $DC01

TIMELINE — ציר זמן (UTC)

08:12 - קליטת הודעת דוא"ל עם קובץ מצורף בסיומת .docm ליעד y.cohen
08:47 - הרצת powershell.exe כתהליך-בן של WINWORD.EXE ב-WKS-YCOHEN
09:15 - יצירת Scheduled Task חדשה ב-WKS-YCOHEN
09:40 - שינוי ערך רישום DisableAntiSpyware ברג'יסטרי של-WKS-YCOHEN
10:05 - ריצת הפקודות whoami /all ו-net group ב-WKS-YCOHEN
10:30 - גישת תהליך rundll32.exe לזיכרון lsass.exe ב-WKS-YCOHEN
11:00 - חיבור RDP לחשבון admin_dana על DC01
11:20 - קריאת קבצים בנתיב \\FS01\Finance$ תחת חשבון admin_dana
12:00 - תעבורת שאילתות DNS בקצב גבוה מ-WKS-YCOHEN לדומיין update-cdn-relay.net. עם subdomain משתנה.
12:20 - חסימת חיבור SMB בין WKS-YCOHEN ל-DB01
12:45 - העברת נתונים יוצאת בנפח 1.4GB מ-WKS-YCOHEN ל filebin-share.net.
13:10 - ריצת הפקודה vssadmin delete shadows בהקשר חשבון svc_backup

✅ CHECKED — מה כבר נבדק ואומת

חסימה של השולח billing-support@invoice-verify-secure.com.
בדיקה איזה עוד משתמשים קיבלו והורידו את המייל פישינג.
בידוד תחנה WKS-YCOHEN.
disable למשתמש y.cohen ו dana_admin.
חסימת הדומיינים filebin-share.net ו update-cdn-relay.net בfirewall.

⏳ NOT CHECKED — ממתין לבדיקת TIER 2

ניתוח פורנזי מלא (Memory/Disk Image) ל-WKS-YCOHEN

Threat Hunting רשתי לאיתור תחנות נוספות שנפגעו.

הערכת תוכן מדויק של הקבצים שהוצאו (רגולציה/דיווח)

הצלבת הממצאים מהאירוע מול Threat Intel כדי לשייך את התקיפה לקבוצת תוקפים ספציפית.

סקירת יומני היסטוריה למציאת Dwell Time מוקדם יותר כדי להבין את עומק האחיזה של התוקף בארגון.

RECOMMENDATIONS — המלצות

הוספת MFA לכל המתשמשים
חיבור feeds של מודיעין איומים ל-SIEM/EDR להתעדכנות אוטומטית שוטפת.
הדרכת Awareness בפישינג כלל-ארגוני ובזיהוי קבצים חשודים.
חסימת גישה ל lsass.exe מתוכנות לא מורשות - הפעלת Credential Guard
סריקת הקבצים ב-Sandbox לפני שמורדים למחשב.
חסימה של powershell.exe מתהליכי אב לא מאושרים.
חסימת RDP ל-DC מכל תחנה רגילה, והתרת גישה רק מתוך שרת קפיצה ייעודי ומאובטח.
אפשור גישה ל DC לפי חוקי חומת אש המבוססים על IP וזהות משתמש ברורה.
הגדרת UEBA המזהה חריגה מנתיב העבודה הרגיל של המשתמש, ושילוב התראה במערכת ה-DLP / SIEM.
חסימת תקשורת של דומיינים עם sub domain בעל אותיות רנדומליות ב NGFW.

SEVERITY — סיווג חומרה

Critical

השתלטות על תחנה,השתלטות על חשבון בקבוצת Domain Admin, גישה לDC, הברחת מאושרת של מידע פיננסי של 1.4 GB , ניסיון פגיעה בתשתית הגיבוי.

הצג / הסתר דוגמת דו״ח מקצועי (מודל השוואה)